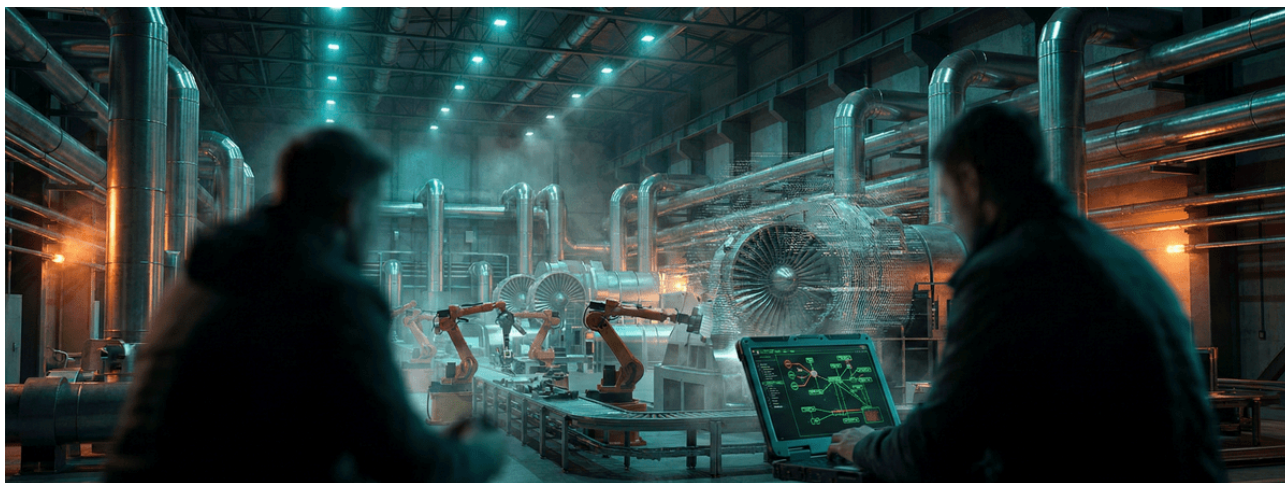


Пентест АСУ ТП (OT/ICS): почему «обычные» IT-подходы могут остановить завод

 redsec.by/article/pentest-asu-tp-otics-pochemu-obychnye-it-podhody-mogut-ostanovit-zavod

Red Teams | 26 ноября 2025



В мире информационной безопасности существует опасная иллюзия: если вы умеете взламывать банковские приложения или корпоративные сети, значит, вы сможете провести аудит безопасности на заводе, электростанции или в логистическом центре. Это заблуждение стоит промышленности миллионов долларов убытков ежегодно, а в худших сценариях — приводит к техногенным катастрофам.

Промышленный сегмент (OT — Operational Technology) и системы управления технологическими процессами (АСУ ТП / ICS) — это не просто «компьютеры, которые управляют станками». Это совершенно иной мир, живущий по своим физическим законам, где цена ошибки измеряется не украденными данными, а человеческими жизнями и разрушенным оборудованием.

Сегодня мы подробно разберем, почему классический инструментарий «белого хакера» смертельно опасен в цехе, как на самом деле нужно защищать критически важные объекты (КВОИ) и почему в белорусских реалиях требования регуляторов (ОАЦ) меняют правила игры.

Фундаментальный конфликт: Царство Доступности против Царства Тайны

Чтобы понять, почему нельзя просто запустить сканер уязвимостей в технологической сети, нужно вернуться к основам. В классической IT-безопасности (банки, ритейл, офисные сети) мы молимся на триаду **CIA**:

- **Confidentiality (Конфиденциальность)** — данные не должны утечь.
- **Integrity (Целостность)** — данные не должны быть изменены.
- **Availability (Доступность)** — система должна работать.

Если в банке обнаружили атаку, безопасники могут временно «положить» сервер, отключить интернет-шлюз или заблокировать учетные записи. Клиенты подождут 10 минут, но деньги останутся целы. Конфиденциальность важнее доступности.

В мире АСУ ТП триада переворачивается с ног на голову и превращается в **AIC** (или даже SAIC, где S — Safety):

- **Availability (Доступность)** — процесс не должен останавливаться ни на секунду.
- **Integrity (Целостность)** — команды управления должны быть верными.
- **Confidentiality (Конфиденциальность)** — часто находится на третьем месте.

Аналогия из реанимации

Представьте, что вы находитесь в палате реанимации. Пациент подключен к аппарату искусственной вентиляции легких (ИВЛ).

- **Подход IT-безопасности:** «Мы подозреваем, что в программном обеспечении ИВЛ есть уязвимость. Давайте перезагрузим его, установим патч и просканируем порты, чтобы убедиться, что хакеры не украдут историю болезни». Результат: пациент умирает от гипоксии, пока устанавливается обновление.
- **Подход ОТ-безопасности:** «Пусть у аппарата открыт 80-й порт, и кто-то может увидеть температуру пациента. Главное — аппарат дышит за человека. Мы не трогаем его, пока он работает. Мы строим стену вокруг палаты, чтобы никто посторонний не вошел».

В промышленности ровно та же ситуация. Доменная печь, химический реактор или турбина электростанции не могут «подождать». Внезапная остановка конвейера на автозаводе — это миллионные убытки. Внезапная остановка насоса на НПЗ — это риск гидроудара, разрыва трубы, пожара и экологической катастрофы. Поэтому приоритет №1 — **не навреди**.

Почему ваш любимый Nmap — это оружие массового поражения в ОТ

Любой начинающий пентестер знает команду nmap -sS -p- -T4. Это агрессивное сканирование всех портов. В корпоративной сети современный сервер просто пожмет плечами и ответит на запросы. Сетевое оборудование Cisco или Juniper даже не заметит нагрузки.

Но когда вы подключаетесь к промышленному коммутатору и запускаете такой скан в сегменте АСУ ТП, происходит страшное.

Хрупкость старых стеков TCP/IP

Многие программируемые логические контроллеры (ПЛК / PLC), которые сегодня управляют критической инфраструктурой, были разработаны 10, 15, а то и 20 лет назад. Их сетевой стек (реализация протоколов TCP/IP) крайне примитивен. Он рассчитан на строго определенный профиль трафика: «пришел запрос от SCADA — отправил ответ».

Когда на такой контроллер обрушивается шквал пакетов от сканера, происходит следующее:

- **Переполнение буфера:** Устройство не успевает обрабатывать новые соединения, его крошечная оперативная память забивается.
- **Отказ в обслуживании (DoS):** Процессор ПЛК тратит 100% ресурсов на обработку сетевого мусора и перестает выполнять главную задачу — управлять физическим процессом (крутить мотор, следить за давлением).
- **Kernel Panic / Watchdog timer:** Устройство считает, что произошло что-то ненормальное, и уходит в «глухую» защиту или перезагружается.

Для технолога это выглядит так: процесс шел нормально, вдруг все лампочки на шкафу автоматики загорелись красным, турбина встала, сработала аварийная защита. Причина — «безопасник решил проверить сеть».

Эффект бутылочного горлышка

Промышленные сети часто используют узкополосные каналы связи — последовательные интерфейсы (RS-485), радиоканалы, старую витую пару. Представьте себе старый мост в провинциальном городке (аналогия №2). Он рассчитан на проезд одной машины раз в минуту. Это нормальный технологический трафик. Агрессивный скан сети — это попытка пустить по этому мосту колонну груженых фур на скорости 100 км/ч. Мост не просто встанет в пробке, он может рухнуть. В АСУ ТП это приводит к потере связи с удаленными объектами (RTU), рассинхронизации данных и переходу системы в аварийный режим.

Вывод профессионала: Активное сканирование в продуктивной сети АСУ ТП строго запрещено или должно проводиться с ювелирной точностью, по согласованным белым спискам и только в периоды планового останова (ППР).

Анатомия промышленных протоколов: «Голые» и доверчивые

Вторая причина, почему IT-подходы не работают «в лоб», кроется в самих языках, на которых общается оборудование. Если в IT мы привыкли к HTTPS, SSH, Kerberos, где есть шифрование и проверка подлинности, то в ОТ царят протоколы из 80-х и 90-х.

Modbus TCP: Классика жанра

Самый популярный протокол в мире. Он прост, надежен, как автомат Калашникова, и так же опасен в неумелых руках. У Modbus **нет аутентификации и нет шифрования**. Вообще. Протокол работает по принципу абсолютного доверия: «Если ты смог прислать мне пакет, значит, ты — Хозяин».

Это означает, что любой злоумышленник (или пентестер), оказавшийся внутри технологического сегмента сети, может отправить команду:

- Остановить процесс (Write Coil).
- Изменить уставку температуры с 200°C на 1200°C (Write Holding Register).
- Сбросить настройки.

Контроллер не спросит пароль. Он просто выполнит команду. Для успешной атаки не нужны эксплойты нулевого дня (0day) или сложные хакерские утилиты. Достаточно простейшего скрипта на Python или стандартной инженерной утилиты.

Siemens S7 (S7comm)

Проприетарные протоколы гиганта индустрии Siemens долгое время страдали теми же проблемами. В старых версиях S7comm (используемых в S7-300, S7-400) команды на чтение и запись памяти, а также на запуск и остановку CPU передавались в открытом виде. Хотя в новых линейках (S7-1200/1500) появилась защита, шифрование и подпись пакетов, на реальных заводах часто встречаются ситуации:

- Режим совместимости («Legacy mode») включен для поддержки старого софта, что отключает защиту.
- Пароли на уровни доступа не установлены или оставлены заводскими.

Риск «случайного выстрела»

При пентесте попытка просто прочитать данные с контроллера нестандартным способом может привести к сбою. Были случаи, когда сканирование порта 102 (S7comm) определенным набором флагов переводило контроллер в режим STOP. На конвейере это означает брак всей партии продукции.

Вектор атаки: Как ломают заводы (IT как плацдарм)

Если протоколы такие дырявые, почему заводы не взрываются каждый день? Потому что спасает «воздушный зазор» (Air Gap) — физическая изоляция технологической сети от интернета. Но давайте будем честными: **Air Gap — это миф**.

В реальности современное производство требует данных. ERP-системе нужно знать, сколько продукции произведено. Инженерам нужен удаленный доступ для настройки. Подрядчикам нужен VPN для диагностики турбин.

Типовой сценарий атаки (Kill Chain):

- **Точка входа:** Хакер атакует не сам завод, а офисную сеть (IT). Фишинг на бухгалтера, взлом слабого VPN, подбор пароля к RDP сисадмина.
- **Закрепление:** Злоумышленник находится в корпоративном сегменте. Он осматривается, повышает привилегии до администратора домена.
- **Поиск моста:** Атакующий ищет серверы, которые имеют «две ноги» — один интерфейс в офисной сети, другой — в технологической. Это может быть сервер истории (Historian), шлюз данных, плохо настроенный Jump-host или компьютер инженера АСУ ТП, который принес ноутбук из цеха в офис «обновить почту».
- **Проникновение в ОТ:** Через этот мост хакер попадает в «святая святых».
- **Воздействие:** Теперь он видит незащищенные контроллеры, SCADA-серверы и операторские панели. Дальше — дело техники. Можно зашифровать все шифровальщиком и потребовать выкуп (как это было с Colonial Pipeline), а можно тихо менять параметры техпроцесса, выводя оборудование из строя.

Этот сценарий показывает, что защита периметра между IT и ОТ — это линия фронта.

Методология правильного пентеста АСУ ТП

Как же проверить защищенность, если нельзя сканировать и эксплуатировать уязвимости? Профессиональный подход строится на других принципах.

1. Пассивное наблюдение (Passive Discovery)

Вместо того чтобы «стучаться» в каждое устройство, мы слушаем. Мы настраиваем SPAN-порт (зеркалирование трафика) на ключевом коммутаторе и подаем копию всего трафика на систему глубокого анализа пакетов (DPI) или специализированное ПО (например, Kaspersky Industrial CyberSecurity, Nozomi, Claroty). Эти системы разбирают промышленные протоколы и рисуют карту сети: «Ага, вот тут у нас Siemens S7-300 общается со SCADA WinCC, а вот тут неизвестное устройство пытается писать в Modbus-регистры». Это абсолютно безопасно для техпроцесса, так как мы не вмешиваемся в передачу данных.

2. Работа на стендах и цифровых двойниках

Если нужно проверить, выдержит ли контроллер атаку, мы **никогда** не делаем это на работающем заводе. Создается стенд: покупается (или берется из ЗИП) точно такой же контроллер, заливается актуальная прошивка и проект. И вот этот «двойник» мы можем атаковать как угодно: фаззить, эксплойтить, DoS-ить. Если он зависнет — никто не пострадает.

3. White Box (Белый ящик) и анализ конфигураций

Вместо попыток взлома «вслепую» (Black Box), аудиторам предоставляют доступ к конфигурациям сетевого оборудования, проектам SCADA и ПЛК. Эксперт анализирует файлы проекта и говорит: «Смотрите, у вас в логике контроллера нет проверки граничных значений. Если оператор (или хакер) введет уставку давления «99999», система попытается ее отработать, что приведет к аварии». Это так называемый «бумажный» аудит, который выявляет 80% проблем без риска положить сеть.

Белорусский контекст: КВОИ и требования ОАЦ

В Республике Беларусь вопросы безопасности АСУ ТП выведены на государственный уровень. Это не просто «хотелки» бизнеса, а требование законодательства.

Крупные промышленные объекты (энергетика, нефтехимия, транспорт, связь, ЖКХ) попадают под определение **Критически Важных Объектов Информатизации (КВОИ)**. В рамках создания национальной системы кибербезопасности, координируемой Оперативно-аналитическим центром при Президенте Республики Беларусь (ОАЦ), к владельцам таких систем предъявляются жесткие требования.

Что это значит на практике?

- **Категорирование:** Предприятие обязано провести обследование, выявить критические процессы и присвоить своим объектам класс типовой информационной системы или категорию критичности.
- **Аттестация:** Системы защиты информации (СЗИ) должны быть сертифицированы и аттестованы. Просто поставить OpenSource фаервол уже недостаточно, нужны решения, прошедшие экспертизу.
- **Киберцентры:** Создаются центры кибербезопасности (SOC), которые должны мониторить инциденты в режиме 24/7 и взаимодействовать с национальным центром (NACK).
- **Регламентированный пентест:** Аудит безопасности КВОИ — это обязательная процедура. Но проводить её имеют право только лицензиаты с соответствующими компетенциями. Отчет о пентесте — это юридически значимый документ.

Для белорусского специалиста по ИБ это означает, что «самодеятельность» в сетях АСУ ТП чревата не только увольнением, но и ответственностью по закону, если действия приведут к нарушению работы критической инфраструктуры.

Требования регулятора подталкивают предприятия к внедрениюложенной защиты:

- Сегментация сети (выделение DMZ).
- Контроль съемных носителей (флешки — главный враг «воздушного зазора»).
- Контроль действий привилегированных пользователей (кто и зачем менял логику ПЛК?).

Итоговое резюме: Как не стать врагом производства

Безопасность АСУ ТП — это искусство компромисса. Ваша задача — закрыть дыры, не задушив процесс.

Ключевые выводы для специалистов:

- **Меняйте мышление:** В ОТ доступность (Availability) и физическая безопасность (Safety) всегда важнее конфиденциальности данных.
- **Забудьте про активный скан:** Любые активные действия в сети — только по письменному согласованию, в окна обслуживания и под присмотром технологов. В приоритете — пассивный мониторинг и анализ трафика.
- **Изучайте протоколы:** Понимайте, как работает Modbus, Profinet, IEC-104. Без этого вы не отличите легитимную команду от атаки.
- **Сегментируйте:** Лучшая защита — это грамотная сетевая архитектура. Изолируйте ОТ от IT, поставьте жесткие правила на межсетевых экранах, используйте промышленные DMZ.
- **Соблюдайте закон:** Работа с КВОИ требует строгого следования нормативным актам ОАЦ и наличия лицензий.

Кибербезопасность производства — это не спринт по поиску багов, а марафон по выстраиванию надежных процессов. И главный приз здесь — не root-доступ, а стабильная, безаварийная работа завода.